

Contents

Ethical Hacking — Mid-Semester Exam Guide (Week 1-5)	1
Week 1 — Introduction, Networking Fundamentals, TCP/IP	1
1.1 Introduction to Ethical Hacking	1
1.2 Fundamentals of Computer Networking	2
1.3 TCP/IP Protocol Stack	3
Week 2 — IP Addressing & Routing, TCP/UDP, Subnets	4
2.1 IP Addressing and Routing	4
2.2 TCP and UDP	5
2.3 IP Subnets	6
Week 3 — Routing Protocols & IPv6	6
3.1 Routing Protocols	6
3.2 IP Version 6	7
Week 4 — Lab Setup & Information Gathering	8
4.1 Creating attacker & victim systems (secure hacking environment)	8
4.2 Information gathering (OSINT / passive + light active)	8
4.3 Nmap for information gathering (Week 4 focus)	10
Week 5 — Vulnerability Scanning, System Hacking, Malware, ARP/MAC	10
5.1 Vulnerability scanning with Nmap and Nessus	10
5.2 System hacking — password cracking, privilege escalation, application execution	11
5.3 Malware and Virus	13
5.4 ARP spoofing and MAC attack	14
Quick Answer Bank (last-minute)	14

Ethical Hacking — Mid-Semester Exam Guide (Week 1-5)

Course: NPTEL 106105217 · Prof. Indranil Sengupta, IIT Kharagpur

Scope: Full official syllabus through Week 5 — nothing skipped

How to use: Each section has **write-ready definitions**, **comparisons**, and **exam lines** you can put on the answer sheet.

Week 1 — Introduction, Networking Fundamentals, TCP/IP

1.1 Introduction to Ethical Hacking

Ethical hacking = authorized security testing of systems with **written permission**. Unauthorized access is illegal (IT Act 2000 in India).

Hat	Meaning
White-hat	Authorized; improves security
Black-hat	Unauthorized; malicious
Grey-hat	No permission, but claims “good intent” — still illegal

CIA triad (write this fully):

Goal	Meaning
Confidentiality	Only authorized people see data
Integrity	Data is not altered without detection
Availability	Systems/services usable when needed

Also mention: **Authentication** (prove identity) and **Non-repudiation** (cannot deny an action).

Penetration testing phases (memorize order):

1. **Reconnaissance** (info gathering)
2. **Scanning** (ports, services, vulns)
3. **Gaining access** (exploit)
4. **Maintaining access** (persistence)
5. **Covering tracks**
6. **Reporting** (findings + remediation)

Threat actors: script kiddies, hacktivists, insiders, organized crime, nation-states.

Exam lines: Ethical hacking needs **explicit written permission**. CVSS rates vulnerability severity 0-10. Scope and Rules of Engagement (RoE) define what is allowed.

1.2 Fundamentals of Computer Networking

Network types & topologies

Type	Scope
LAN	Local building / campus
MAN	City-scale

Type	Scope
WAN	Across cities / countries

Topologies: bus, star, ring, mesh, hybrid. Star: single switch failure isolates nodes. Mesh: most fault-tolerant.

OSI 7-layer model (bottom → top)

Layer	Name	PDU	Examples
1	Physical	bits	cables, signals
2	Data Link	frame	Ethernet, MAC, switches
3	Network	packet	IP, routers, ICMP
4	Transport	segment (TCP) / datagram (UDP)	TCP, UDP
5	Session	data	session control
6	Presentation	data	encryption, encoding
7	Application	data	HTTP, DNS, FTP, SSH

Switch = Layer 2 (MAC → port via CAM table). **Router = Layer 3** (IP routing).

MAC address: 48-bit hardware address (OUI + device). Broadcast MAC = FF:FF:FF:FF:FF:FF.

VLAN (802.1Q): logical segmentation; 4-byte tag in Ethernet frame.

MAC flooding / CAM overflow: flood random source MACs → CAM table fills → switch floods frames to all ports (acts like a hub) → attacker can sniff.

Defense: port security (limit MACs per port), DAI, 802.1X.

1.3 TCP/IP Protocol Stack

TCP/IP has 4 layers (vs OSI 7):

TCP/IP layer	Rough OSI map	Key protocols
Application	5-7	HTTP(80), HTTPS(443), DNS(53), SMTP(25), FTP(21), SSH(22), Telnet(23)
Transport	4	TCP, UDP
Internet	3	IP, ICMP, ARP
Network Access	1-2	Ethernet, Wi-Fi

Encapsulation: Application data → TCP/UDP segment → IP packet → Ethernet frame.

IP header must-know:

- **TTL** — decremented each hop; prevents infinite loops
- **Protocol field** — TCP=6, UDP=17
- IP provides addressing/routing only — **no reliability**

Ports: well-known 0-1023; registered 1024-49151; ephemeral 49152-65535.

Socket = IP + port + protocol.

DNS: mainly **UDP 53** (TCP for zone transfers / large replies). Records: A, AAAA, MX, NS, TXT, SOA.

DHCP (DORA): Discover → Offer → Request → Acknowledge.

Exam lines: TCP/IP = 4 layers; OSI = 7. Telnet sends credentials in cleartext — never use in production.

Week 2 — IP Addressing & Routing, TCP/UDP, Subnets

2.1 IP Addressing and Routing

IPv4: 32-bit, dotted decimal (e.g. 192.168.1.10).

Private ranges (RFC 1918) — write all three:

Range	Prefix
10.0.0.0 - 10.255.255.255	/8
172.16.0.0 - 172.31.255.255	/12
192.168.0.0 - 192.168.255.255	/16

Special: loopback 127.0.0.0/8 (127.0.0.1); link-local 169.254.0.0/16.

CIDR replaced classful A/B/C. Notation: IP/prefix (e.g. /24 = mask 255.255.255.0).

NAT: maps many private IPs to fewer public IPs (hides internal topology).

Routing table: destination network, next-hop, interface, metric.

Default route: 0.0.0.0/0 → gateway.

Longest prefix match: most specific route wins.

Routing type	Idea
Static	Manually configured; predictable; no auto-failover

Routing type	Idea
Dynamic	Routers exchange topology via protocols

Traceroute works by sending packets with increasing TTL and collecting ICMP Time Exceeded messages.

2.2 TCP and UDP

Feature	TCP	UDP
Connection	Connection-oriented	Connectionless
Reliability	Reliable, ordered	Best-effort
Overhead	Higher	Lower
Use cases	HTTP, SSH, FTP	DNS, VoIP, streaming

TCP three-way handshake (write with sequence idea):

1. Client → Server: **SYN** (seq = x)
2. Server → Client: **SYN-ACK** (seq = y, ack = x+1)
3. Client → Server: **ACK** (ack = y+1)

Teardown: FIN/ACK exchange (four-way) or **RST** for abrupt close.

TCP flags: SYN, ACK, FIN, RST, PSH. Sliding window = flow control.

Scan types (exam favourites):

Scan	Idea
SYN (-sS)	Half-open; stealthier; needs root
Connect (-sT)	Full handshake; logged
FIN / NULL / Xmas	Odd flags; closed port → RST (RFC 793)
UDP (-sU)	ICMP Port Unreachable ⇒ closed

Filtered = firewall drops probe (no reply). **Closed** = RST (TCP) or ICMP unreachable (UDP).

2.3 IP Subnets

Subnetting = split one network into smaller broadcast domains.

- Usable hosts $\approx 2^{(32-\text{prefix})} - 2$ (subtract network + broadcast addresses)
- /24 → 256 addresses, **254 usable hosts**
- /30 → 4 addresses, **2 usable** (point-to-point links)

VLSM: different subnet sizes in one network (efficient allocation).

Supernetting: aggregate routes (e.g. several /24 → one /22).

Exam calculation tip: AND the IP with the subnet mask → network address.

Week 3 — Routing Protocols & IPv6

3.1 Routing Protocols

Interior vs Exterior

Class	Where used	Examples
IGP (Interior)	Inside one AS	RIP, OSPF, EIGRP
EGP (Exterior)	Between ASes	BGP

RIP (distance-vector)

- Metric = **hop count**; max **15** hops (16 = unreachable / infinity)
- Updates about every **30 s**; uses **UDP 520**
- “Routing by rumor”; slow convergence; count-to-infinity problem
- **Split horizon**: don’t advertise a route back out the interface it was learned on
- **Route poisoning**: advertise failed route with metric 16
- RIPv2: CIDR + multicast updates; can use authentication

OSPF (link-state)

- Builds a **full topology map**; uses **Dijkstra SPF**

- **Area 0** = backbone; all areas connect to Area 0
- Metric = **cost** $\approx$ reference bandwidth / link bandwidth
- Floods **LSAs** (Link State Advertisements)
- Hello packets discover neighbors

BGP (path-vector)

- Routes **between autonomous systems**
- Uses **TCP port 179**
- Key attribute: **AS-PATH** (list of ASes traversed; also detects loops)
- Policy-based; can be hijacked by announcing prefixes you don't own
- Defense idea: RPKI, prefix filtering

Administrative distance (Cisco — lower is preferred)

Source	AD
Static	1
EIGRP	90
OSPF	110
RIP	120
iBGP	200

Write comparison: RIP = simple hop-count distance-vector; OSPF = fast link-state with areas; BGP = inter-AS path-vector on TCP 179.

3.2 IP Version 6

- Address size: **128 bits**, hexadecimal with : (e.g. 2001:db8::1)
- Types: unicast, **multicast** (no broadcast), anycast
- Loopback: ::1

- Link-local: **fe80::/10**
- Unique local: **fc00::/7**

NDP (Neighbor Discovery Protocol) replaces **ARP**; uses ICMPv6 (RS, RA, NS, NA).

SLAAC: host auto-configures address from Router Advertisement prefix.

DHCPv6: managed addressing alternative.

Attacks: rogue Router Advertisement; NDP spoofing (IPv6 MITM).

Defenses: RA Guard, SEND, IPv6 firewall rules.

Week 4 — Lab Setup & Information Gathering

4.1 Creating attacker & victim systems (secure hacking environment)

Goal: isolated lab so attacks stay inside your VMs.

Role	Typical setup
Attacker	Kali Linux VM (tools preinstalled)
Victim	Metasploitable, Windows XP/7 unpatched, DVWA, etc.
Hypervisor	VirtualBox / VMware

Secure lab rules (write these):

1. Use **host-only** or **internal** network — not bridged to real Internet for attack traffic.
2. Take **snapshots** before risky experiments.
3. Never scan or attack systems **outside written authorization**.
4. Separate management VLAN / no shared credentials with production.
5. Keep attacker tools updated; document scope.

This is the “secure hacking environment” idea: safe sandbox + legal authorization.

4.2 Information gathering (OSINT / passive + light active)

Passive recon = no direct contact with target (OSINT).

Active recon = send packets to target (will be logged).

Tools in the syllabus — know what each does

Tool / source	What you get
Advanced Google search (dorks)	Hidden pages, files: site:, filetype:, inurl:, intitle:
archive.org (Wayback Machine)	Old versions of sites, deleted pages, historical tech stack
Netcraft	Hosting history, OS/server hints, uptime, site report
whois	Registrar, name servers, contacts, IP ranges, registration dates
host	Simple DNS lookup (A / MX etc.)
dig	Detailed DNS queries (dig domain ANY, dig @ns domain AXFR)
dnsenum	Automates subdomain enum, zone-transfer attempts, brute-force
Nmap	Host discovery, port/service scan, OS/version detection

Typical recon workflow (answer as numbered steps)

1. **WHOIS** → IP ranges, NS, contacts
2. **DNS** (host / dig / dnsenum) → subdomains, mail servers, zone-transfer check
3. **Google + archive.org + Netcraft** → public footprints, old content, hosting
4. Document findings
5. Only then **Nmap** (active)

Commands worth writing:

```
whois example.com
host example.com
dig example.com ANY
dig @ns1.example.com example.com AXFR
dnsenum example.com
```

Defenses: WHOIS privacy, disable unauthorized AXFR, minimize public tech details, employee awareness.

4.3 Nmap for information gathering (Week 4 focus)

Flag	Meaning
-sn	Ping sweep / host discovery (no port scan)
-sS	SYN (stealth) scan
-sT	TCP connect scan
-sU	UDP scan
-sV	Service version detection
-O	OS fingerprinting
-A	Aggressive: OS + version + scripts + traceroute
-p-	All 65535 ports
-p 80,443	Specific ports

```
nmap -sn 192.168.1.0/24
```

```
nmap -sS -sV -O 192.168.1.10
```

```
nmap -A target
```

Exam lines: -sn finds live hosts; -sV finds service versions; active Nmap traffic **will be logged**.

Week 5 — Vulnerability Scanning, System Hacking, Malware, ARP/MAC

5.1 Vulnerability scanning with Nmap and Nessus

Nmap as vulnerability scanner

- **NSE (Nmap Scripting Engine):** Lua scripts
- Categories include: default, discovery, vuln, brute, exploit, safe, intrusive

```
nmap --script vuln target
```

```
nmap --script smb-enum-shares target
```

```
nmap --script=default,vuln -sV target
```

Evasion (mention if asked): -f fragment packets; -D RND:10 decoys; --scan-delay slow scan.

Output: -oN normal, -oX XML, -oA all formats.

Nessus

Nessus (Tenable) = commercial vulnerability scanner (Essentials free tier ~16 IPs).

Fact	Detail
Web UI	https://localhost:8834
Service	nessusd
Scan types	Credentialed (deeper) vs non-credentialed (remote)
Severity	Critical / High / Medium / Low / Info (CVSS-based)
Plugins	Signature feed of vulnerability checks

Workflow: New Scan → choose template (Basic / Advanced) → set targets → launch → review Critical/High → verify manually → export report.

Credentialed scans log into the target → better patch-level findings. Always **verify false positives** before reporting.

Nmap vs Nessus (comparison question):

	Nmap	Nessus
Strength	Flexible host/port/service + NSE	Deep vuln database + remediation advice
Style	CLI / scriptable	Web UI + reports
Best for	Mapping + targeted scripts	Full vulnerability assessment reports

5.2 System hacking — password cracking, privilege escalation, application execution

Password cracking

Passwords must be stored as **hashes** (ideally salted + slow: bcrypt/Argon2), never plain-text.

System	Hash notes
Windows	NTLM = MD4 of UTF-16LE password; old LM = weak, 7-char chunks
Linux	/etc/shadow: \$1\$ MD5, \$5\$ SHA-256, \$6\$ SHA-512, \$2a\$ bcrypt

Attack types:

Attack	Idea
Dictionary	Try wordlist (e.g. rockyou.txt)

Attack	Idea
Brute-force	All combinations
Hybrid / rules	Wordlist + mutations
Rainbow tables	Precomputed hashes — defeated by salting
Pass-the-hash	Use NTLM hash directly without cracking plaintext

Tools: John the Ripper, Hashcat, Hydra (online brute-force), Mimikatz (memory hashes).

```
john --wordlist=rockyou.txt hashes.txt
hashcat -m 1000 -a 0 hashes.txt rockyou.txt # 1000 = NTLM
hydra -l admin -P passwords.txt ssh://target
```

Defenses: long unique passwords, MFA, lockout/rate-limit, Argon2/bcrypt, Credential Guard.

Privilege escalation & application execution (Metasploit angle)

Metasploit Framework (MSF): Rapid7 pentest platform.

Module type	Role
Exploit	Delivers payload against a CVE
Payload	Code run on target (shell, Meterpreter)
Auxiliary	Scan/brute — no exploit payload
Encoder	Obfuscate payload
Post	After access: dump hashes, persist, enumerate

Key variables: RHOSTS = target; LHOST = attacker callback.

Meterpreter commands for exams:

Command	Purpose
sysinfo	OS / architecture
getuid	Current user privileges
getsystem	Escalate to SYSTEM (Windows)
hashdump	Dump NTLM hashes from SAM
migrate	Move into another process
shell / execute apps	Run commands / applications on victim

Privilege escalation flow:

1. Gain low-privilege shell
2. `getuid` → see privileges
3. `local_exploit_suggester` or `getsystem` / local exploit
4. `hashdump` → crack or pass-the-hash
5. Run applications / tools as elevated user

msfvenom = generate standalone payloads outside the console.

Defenses: least privilege, patch local privesc CVEs, disable SMBv1 / patch EternalBlue-class bugs, EDR.

5.3 Malware and Virus

Type	Key point (write this)
Virus	Needs a host program ; spreads when host runs
Worm	Spreads by itself over networks
Trojan	Disguised as useful software; user runs it
Ransomware	Encrypts data; demands payment
Spyware	Secretly steals information
Rootkit	Hides at kernel/firmware level
Adware	Unwanted ads / tracking
RAT	Remote Access Trojan — full remote control

Propagation: email attachments, drive-by downloads, USB, exploit kits, lateral movement.

Persistence: registry Run keys, scheduled tasks, services, DLL hijacking.

Anti-analysis: packing, obfuscation, VM detection.

Defenses: EDR/AV, application whitelisting, disable Office macros by default, backups (ransomware), network C2 monitoring.

Classic distinction question: Virus needs host; worm is self-replicating; trojan tricks the user.

5.4 ARP spoofing and MAC attack

ARP basics

ARP maps **IP** → **MAC** on a LAN (Layer 2). **No authentication** → easy to spoof.

ARP spoofing / poisoning (MITM)

Attacker sends fake ARP replies so:

- Victim thinks gateway IP = **attacker MAC**
- Gateway thinks victim IP = **attacker MAC**

Traffic both ways flows through the attacker (**bidirectional** poison). Attacker must enable **IP forwarding** to relay packets (or victim loses connectivity).

```
echo 1 > /proc/sys/net/ipv4/ip_forward
arpspoof -i eth0 -t victim gateway
# poison both sides in a real lab
```

Tools: arpspoof (dsniff), Ettercap, Bettercap. Related: DNS spoofing, SSL stripping, session hijacking.

MAC attack (CAM flooding)

Flood switch with fake source MACs → **CAM table overflow** → switch fails open and floods frames → sniffing possible.

Defenses (write both):

Attack	Defenses
ARP spoof	Static ARP for gateway; Dynamic ARP Inspection (DAI) ; 802.1X; HTTPS/HSTS/VPN
MAC flood	Port security (limit MACs per port); sticky MAC; disable unused ports

Exam lines: ARP is Layer 2 and unauthenticated. MITM needs poison of **both** victim and gateway. MAC flooding turns switch into hub-like flooder.

Quick Answer Bank (last-minute)

1. **CIA** — Confidentiality, Integrity, Availability.

2. **Pentest order** — Recon → Scan → Access → Maintain → Cover → Report.
3. **OSI L2/L3** — Switch/MAC/frame vs Router/IP/packet.
4. **TCP/IP layers** — 4 layers; TCP reliable; UDP fast.
5. **Handshake** — SYN → SYN-ACK → ACK.
6. **RFC 1918** — 10/8, 172.16/12, 192.168/16.
7. **/24** — 254 usable hosts.
8. **RIP** — hop count, max 15, UDP 520.
9. **OSPF** — link-state, Dijkstra, Area 0 backbone.
10. **BGP** — path-vector, TCP 179, AS-PATH.
11. **IPv6** — 128-bit; NDP replaces ARP; fe80::/10 link-local; no broadcast.
12. **Passive vs active recon** — no packets to target vs scanning.
13. **whois / dig / dnsenum / Google / archive.org / Netcraft / Nmap** — know one line each.
14. **Nmap** -sn -sS -sV -O -A --script vuln.
15. **Nessus** — port 8834; credentialed deeper; CVSS severities.
16. **Hash crack** — dictionary vs brute; salt beats rainbow tables; PTH uses hash as-is.
17. **Metasploit** — exploit/payload/post; RHOSTS/LHOST; getsystem/hashdump.
18. **Virus vs worm vs trojan** — host / self-spread / disguise.
19. **ARP MITM** — fake ARP replies both ways + IP forwarding.
20. **MAC flood** — fill CAM → flood → sniff; stop with port security.

Study material for NPTEL Ethical Hacking mid-sem (Weeks 1-5). Offensive techniques are for authorized labs and exams only.